

Seguridad Informática

UNIVERSIDAD DE SANTIAGO DE COMPOSTELA

UNIÓN DE EXÁMENES

Resumen

En este documento se recoge la unión de todas las preguntas de los exámenes de años anteriores de la asignatura de Seguridad Informática, junto con sus respuestas.

AUTOR:

- Pedro Gamallo Fernández
- Manuel González Costa

FECHA: 15 de enero de 2021

Índice

1. Examen 2013	2
2. Examen 2016	8
3. Examen 2009	10

1. Examen 2013

1. Servicios básicos de la seguridad.

- **Autenticación:** Asegurar que el origen de la información es quien dice ser.
- **Confidencialidad:** Impedir que la información/recursos sean vistos por quien no debe.
- **Integridad:** Asegurar que la información no se modifica cuando se transmite o almacena.
- **No repudio:** Impedir que alguien niegue haber realizado una transacción cuando efectivamente la ha hecho.
- **Control de acceso:** Controlar quien puede acceder a los datos/recursos.
- **Disponibilidad:** Los datos y recursos están disponibles cuando se requieren.

2. ¿Qué es un CERT?. Indica algún servicio que ofrece.

Un **CERT** es un equipo de respuesta ante emergencias informáticas. Está formado por expertos en seguridad informática que actúan como centro de coordinación de avisos de seguridad a nivel local, estatal o global. Algunos de los servicios que ofrecen son:

- Soporte y coordinación, para el tratamiento de vulnerabilidades y resolución de incidencias.
- Investigación y divulgación de las mejores prácticas de seguridad.
- Información sobre vulnerabilidades, alertas y avisos.

3. ¿Qué es una cookie?. ¿Para qué sirve?

Una cookie es un mecanismo de recolección de información empleado por los sitios web. La información es almacenada localmente en el navegador del usuario, de manera que el sitio web puede consultar la actividad previa del usuario. Sus principales funciones son:

- Permitir al usuario emplear ciertos servicios del sitio web (cookies técnicas).
- Recordar las preferencias de personalización del usuario (cookies de personalización).
- Controlar los gustos y hábitos de los usuarios y la publicidad que se les muestra (cookies de publicitarias y de publicidad comportamental).
- Llevar un seguimiento de los usuarios que visitan un sitio web y sus hábitos (cookies técnicas).

4. Fases del SGSI.

Ciclo PDCA:

- **Plan:** Planificar y diseñar el SGSI (definir las políticas, identificar los riesgos...).
- **Do:** Implantación y gestionar el SGSI y los controles definidos.
- **Check:** Revisar el SGSI, medir la eficacia de los controles y realizar auditorías.
- **Act:** Implantar las mejoras y los cambios necesarios.

5. ¿Qué es un activo, riesgo, amenaza y vulnerabilidad?. Relación entre ellos.

- Un **activo** es aquello que tiene algún valor para la organización y debe protegerse. Un activo de información es aquel elemento que contiene o manipula información.
- Un **riesgo** es la posibilidad de que una amenaza explote una vulnerabilidad de un activo y cause su daño o pérdida.
- Una **amenaza** es un evento (intencionado o no) que tiene el potencial de dañar un activo.
- Una **Vulnerabilidad** es una debilidad en el activo que puede ser explotada por una amenaza.

6. Explica cómo funciona el cifrado de flujo.

A partir de una clave (semilla) se genera una secuencia pseudoaleatoria que se combina con el mensaje original. La secuencia pseudoaleatoria tiene el mismo tamaño que el mensaje a codificar, y la codificación puede ser un simple XOR. Propuesta de cifrador hecha en 1917 por Vemam:

- Una cifra basada en la función XOR.
- Una secuencia cifrante binaria y aleatoria S que se obtiene de una clave secreta K compartida por emisor y receptor.
- Un algoritmo de descifrado que es igual a la de cifrado por la involución de la función XOR.

7. Propiedades del resumen criptográfico (Hash).

Propiedades del resumen criptográfico:

- El resumen debe ser “corto” y siempre de la misma longitud.
- El algoritmo debe ser irreversible.
- Dos mensajes distintos deben generar dos resúmenes diferentes.

8. Explica la fortaleza del algoritmo RSA.

El algoritmo RSA es un algoritmo de cifrado por exponenciación. Su principal fundamento y fortaleza es la dificultad de factorizar números primos grandes y de calcular logaritmos discretos con módulo grande.

9. Explica los pasos a seguir entre dos usuarios A y B para establecer una comunicación segura con criptografía híbrida.

A cifra mensaje original con una clave simétrica (clave de sesión), y a su vez cifra esta clave simétrica con la clave pública de B, garantizando así la confidencialidad (solo B podrá descifrarla).

B recibe el mensaje y la clave cifrados. Primero descifra la clave de sesión con su clave privada, y posteriormente la emplea para descifrar el mensaje original.

10. ¿Qué es una autoridad de registro?.

Una autoridad de registro es una entidad que verifica la identidad del usuario y proporciona a la CA dichos datos junto con su aprobación. Otros servicios que ofrece son:

- Facilitar el registro de usuarios.
- Generación de par de claves privadas/públicas.
- Prueba de posesión: comprobar que el solicitante posee la clave privada correspondiente.

11. Cortafuegos: pasos a seguir para establecer una conexión segura en https.

- Búsqueda de componentes sospechosas, por ejemplo, líneas muy largas.
- Si se encuentran, se descarta la petición.
- Si no, se redirige al servidor.

12. Explica la vulnerabilidad TOCTOU. ¿Cómo podemos arreglarla?.

Es una vulnerabilidad relacionada con la sincronización y el control de acceso, cuando hay operaciones secuenciales en el proceso. Entre la primera operación y la segunda hay un intervalo de tiempo (ventana de vulnerabilidad) en la que se puede explotar la vulnerabilidad. En el caso de trabajar con ficheros, puede ser el intervalo entre cuando se comprueban los permisos de acceso al fichero y cuando éste se abre, como en el caso de *xterm*.

Para evitarla deben usarse funciones que trabajen con los identificadores de los ficheros o punteros a fichero, en lugar de con el nombre de los mismos. Otra opción es almacenar los archivos en un directorio solo accesible por el UID del programa.

13. Explica el desbordamiento de memoria.

El desbordamiento de memoria (**buffer overflow**) se produce cuando un programa intenta almacenar más datos en el buffer que los que permite su tamaño. Los datos “extra” sobrescriben la zona de memoria adyacente al buffer, corrompiendo datos válidos y posiblemente modificando el flujo de ejecución del programa.

14. ¿Qué es un rootkit?

Es un código malware que intercepta las llamadas a determinadas funciones del sistema, modificando la salida de las mismas para, generalmente, ocultarse a si mismos o a otros malware del sistema.

15. Gusanos. ¿Cómo se difunde?

Los gusanos se difunden a través de la red pasando de unos ordenadores a otros de forma automática o con alguna ayuda extra. Generalmente usan alguna de las siguientes estrategias para descubrir nuevos objetivos en la red:

- Buscar direcciones de correo en el sistema infectado.
- Escanear la red en busca de vulnerabilidades.
- Generar automáticamente direcciones IP.

16. Esquema general de nombres de virus.

<malware_type>://<platform>/<family_name>.<group_name>.

<infective_length>.<variant><devolution><modifiers>

17. Di tres técnicas de cómo puede un virus convertirse en retrovirus.

- Ejecutar el código del virus a través del antivirus.
- Trojanizar la base de datos del antivirus.
- Deshabilitar o matar el programa antivirus, o programas cortafuegos.

18. Explica el protocolo que se utiliza en SSL.

En la asociación entre un cliente y un servidor en SSL (inicio de la sesión SSL) se utiliza el protocolo de negociación (*handshake*). Por medio de este protocolo, cliente y servidor intercambian certificados y definen la *suite de cifrado* y un conjunto de parámetros de seguridad que se utilizarán en la conexión;

- Identificador de sesión.
- Certificado de la entidad par.
- Método de comprensión.
- Especificación del cifrado.
- Clave maestra.
- Reanudable: sí/no.

19. Explica que es DMZ.

DMZ es una subred intermedia entre Internet y la intranet. En la DMZ se instalan los servidores de acceso público como Web, e-mail, FTP o DNS. Los accesos a la intranet pasan previamente por la DMZ, dando paso a la red externa sólo a lo imprescindible. Se instalan sistemas de filtrado y detección antivirus previo al envío a la intranet.

20. Explica el protocolo IPsec: AH y ESP.

El protocolo IPsec proporciona mecanismos de seguridad para proteger el tráfico IP. Emplea dos protocolos diferentes (AH y ESP) para asegurar la autenticación, integridad y confidencialidad de la comunicación.

- AH: Autenticación de la cabecera. Garantiza la integridad y autenticación de los datos calculando un resumen HMAC con clave secreta.
- ESP: Encapsulación de los datos. Garantiza confidencialidad definiendo como se cifran los datos.

21. Cinco diferencias entre criptografía simétrica y asimétrica.

En la siguiente tabla tenemos nueve diferencias entre criptografía simétrica y asimétrica:

Cifrado simétrico	Cifrado asimétrico
Una única clave	Dos claves (pública y privada)
Ambas partes funcionan igual	Las partes no son iguales
No permite autenticación	Permite autenticación
No permite no repudio	Permite no repudio
Para n participantes, $n * (n-1) / 2$ claves	Para n participantes, $2 * n$ claves
Espacio de claves ≥ 128 bits	Espacio de claves ≥ 1024 bits
Vida de las claves muy corta	Vida de las claves muy larga
Velocidad muy alta	Velocidad muy baja
La seguridad reside en la propia clave	La seguridad reside en la dificultad computacional

22. Explica el ataque SYN. ¿Cómo podemos evitarlo?.

Ataque SYN flooding: Ataque específico contra el protocolo *TCP*. Es un tipo de ataque de denegación del servicio (*DoS*) mediante el cual el atacante envía muchas peticiones *SYN* (para establecer una nueva conexión *TCP*) a la víctima, **falsificando la dirección de origen por una inexistente**. Al no recibir los *ACK* de vuelta, la víctima va acumulando las peticiones hasta desbordarse.

23. Ejemplo de cortafuegos, de filtrado de paquetes y cortafuego de JUI y YETWEI.

JUI y YEWEL non os conocen nin na súa casa.

24. Explica las dos estrategias de un sistema de detección de intrusiones.

Reconocimiento de firmas y patrones:

- Se asumen que toda actividad intrusiva es representable mediante un **patrón único** o *firma*.
- Los datos obtenidos en la monitorización se comparan con bases de datos de firmas conocidas de ataques.
- Los proveedores incluyen actualizaciones de las firmas en las bases de datos frecuentemente.

Detección de anomalías:

- **Análisis estadístico:** Buscar comportamientos que difieren de los patrones normales.
- **Sistemas de aprendizaje:** Técnicas basadas en *IA* que detectan comportamientos que difieren de los esperados (aprendidos).

2. Examen 2016

6. Propiedades del resumen criptográfico en la firma digital.

Los algoritmos de resumen criptográfico son irreversibles y generan resúmenes distintos para mensajes distintos. Gracias a esto, se pueden conseguir las propiedades deseables en la firma digital de no ser alterable ni reutilizable (si se varía el contenido inicial, el resumen será distinto y por tanto variará la firma).

7. Describe el cifrado AES-256-EDC.

Es un tipo de cifrado por bloques que emplea una matriz 4x4 para cifrar bloques de 128 bits por medio de operaciones de permutación y sustitución. En este caso, debido al nombre, sabemos que emplea una clave de 256 bits y contiene detección y corrección de errores (EDC: Error Detection and Correction).

12. Describe los tres mecanismos mediante los que se difunden los gusanos.

Tres técnicas de difusión que emplean los gusanos para localizar nuevos objetivos son:

- Buscando en direcciones de correo del sistema infectado actual.
- Escaneando la red en busca de vulnerabilidades.
- Generando direcciones IP de forma aleatoria.

13. ¿Qué información se puede extraer de la siguiente entrada de una base de datos de un antivirus?: Trojan://Multi/Jederx.XX@IM+P2P+Otros

- **Trojan:** Es un malware del tipo troyano.
- **Multi:** Está pensado para varias plataformas.
- **Jederx:** Nombre identificativo del malware.
- **XX:** Variante del malware dentro de los troyanos Jerdex
- **@IM+P2P+Otros:** Modificadores, indican que ataca correos electrónicos, sistemas P2P y otros.

20. ¿En qué consiste un web bug y para qué suele utilizarse?

Imágenes inapreciables a la vista (tamaño 1x1 sin bordes) insertadas en el *HTML* del sitio web que registran la visita del usuario recolectando información del mismo (como la dirección IP, el sistema operativo, la versión del navegador...).

En el atributo *src* de la imagen se inserta una dirección web en la que reside un programa específico encargado de anotar los datos del usuario de forma automática.

21. Explica cómo detectan los antivirus un ejecutable PE infectado.

Los antivirus detectan códigos maliciosos utilizando **firmas** o **huellas** en los ficheros de los programas. Para ello buscan patrones conocidos de cadenas de código, almacenamiento o ejecución relacionados con los códigos maliciosos.

22. Describe las dos técnicas utilizadas por los cortafuegos para el filtrado de paquetes.

- **Aceptar todo por defecto:** Se acepta la entrada de todos los paquetes, salvo aquellos que concuerden específicamente con alguna de las reglas definidas en el cortafuegos, los cuales se descartan.
- **Rechazar todo por defecto:** Solo se aceptan los paquetes que concuerden con alguna de las reglas definidas en el cortafuegos. Los demás se descartan por defecto.

23. ¿Qué diferencia existe entre un test de seguridad y un test de funcionalidad para un software?

- **Test de funcionalidad:** Trata de verificar que la aplicación funcione correctamente en **situaciones normales** o esperadas.
- **Test de seguridad:** Trata de verificar que la aplicación funcione según lo esperado en **situaciones anormales** (entradas erróneas, intentos de conexión fallidos...).

24. Cita tres de las respuestas básicas de un sistema IDS/IPS frente a un evento de intrusión detectado.

- Generar alarmas y registrarlas.
- Reconfigurar el cortafuegos.
- Cortar la conexión TCP si detecta un ataque.

3. Examen 2009

2. Enumera dos problemas de la criptografía simétrica en relación con su uso en Internet.

- Si mandamos un sms cifrado por internet, como sabe la persona cuál es la clave con la que tiene que descifrar el sms.
- Tener tantas claves como pares de personas quieran comunicarse.

4. ¿Cuál de las siguientes no es una propiedad necesaria para un algoritmo de cálculo del extracto digital?

1. El algoritmo debe ser irreversible
2. Dos mensajes diferentes deben generar dos extractos diferentes
3. Todos los extractos tendrán la misma longitud
4. Debe existir un procedimiento para poder recuperar el texto original

NOTA: No entra en el 20/21

5. ¿En qué consiste la firma digital, y qué garantiza?

Garantiza, en el mundo digital, la **autenticidad** y la **integridad** de un mensaje.

6. ¿Cuáles son los pasos habituales a seguir para obtener un certificado digital de usuario emitido por una autoridad certificadora?

Tener una clave pública y una clave privada. En la clave pública añadir nuestros datos e ir a una autoridad de registro que valide esos datos y finalmente que una CA Firme los datos con su clave privada.

7. Indica un mecanismo alternativo al uso de infraestructuras PKI, y su funcionamiento.

La respuesta se referiría al “Anillo de confianza”, pero **NOTA:** No entra en el 20/21

8. ¿Qué crees que hace el siguiente comando?: openssl dgst -md5 -out salida texto

Genera un extracto digital de texto con el algoritmo md5 y lo guarda en salida.

NOTA: No entra en el 20/21

9. ¿Quién puede ejecutar una cookie?

1. Solamente el navegador que la almacenó
2. El servidor que depositó la cookie
3. Las cookies no son ejecutables
4. Los programas que tengan permiso de ejecución para el usuario que la depositó

NOTA: Pregunta trampa, las cookies no se ejecutan

NOTA: No entra en el 20/21

11. ¿En qué consiste el “phishing”?

Ataque de ingeniería social que pretende engañar a la víctima para que proporcione información privada.

12. ¿Cuál es la ventaja de utilizar un Proxy web desde el punto de vista de la privacidad?

Que en los sitios que visitemos quedará como dirección de origen la del Proxy, no la nuestra (aunque en el proxy sí que quedará registrada la nuestra) y así estaremos más protegidos.

13. Explica cómo funcionan los virus que modifican el campo AddressOfEntryPoint de los archivos PE.

NOTA: No entra en el 20/21

15. Según el esquema de nombres propuesto por CARO, algunos virus contienen en su nombre el sufijo @mm. ¿Qué significa?

1. Que son virus altamente infecciosos
2. Que se distribuyen a través de correos masivos
3. Que necesitan de un gestor de correo para infectar
4. Que son virus de master memory

NOTA: No entra en el 20/21

16. ¿Para qué tipos de virus está especialmente indicada la detección por “emulación de código”?

1. Sector de arranque
2. Sigilosos
3. **Polimórficos**
4. De cavidad

NOTA: No entra en el 20/21

17. Cita dos técnicas que se empleen habitualmente para “ofuscar” el código, para protegerlo frente a los desensambladores.

Meter instrucciones de salto o meter instrucciones que no hacen nada. (Aquí son más o menos las que se nos ocurran a nosotros)

18. Describe una de las mejoras empleadas por los antivirus de tipo scanner de primera generación para mejorar su rendimiento.

Añadir comodines en la búsqueda y, en vez de escanear todo el fichero, escanear el principio y el final o solo el medio dependiendo del tipo de virus.

20. Describe brevemente cómo se puede realizar un ataque mediante desbordamiento de la pila.

1. El atacante coloca su código en una zona de la pila del programa.
2. El desbordamiento de la pila se produce con instrucciones de salto hacia la zona en la que está el código malicioso.

21. Explica el significado del dígito más significativo en una máscara de permisos en octal de 4 dígitos. Aplicado al ejemplo siguiente: 6750, ¿qué indica?

NOTA: No entra en el 20/21

22. ¿Qué hace el siguiente fragmento de código? fchown(fid,110,-1)

No entra en el 20/21